# WEEK 1 – ENVIRONMENT SETUP AND RECONNAISSANCE

Web Application Penetration Testing is an important cybersecurity practice used to identify vulnerabilities present in web applications before attackers can exploit them. Modern web applications often contain security weaknesses related to authentication, authorization, input validation, and data protection.

To understand these vulnerabilities in a practical manner, a testing environment was created using OWASP Juice Shop and DVWA (Damn Vulnerable Web Application). Burp Suite was used for web application traffic analysis and reconnaissance, while Nmap was used to identify active services running on the target environment.

This week mainly focused on understanding the OWASP Top 10 vulnerabilities, configuring the penetration testing environment, and performing reconnaissance activities required before vulnerability testing.

The primary objectives of Week 1 were:

- To study OWASP Top 10 Web Application Security Risks.
- To set up a vulnerable web application testing environment.
- To deploy OWASP Juice Shop using Docker.
- To verify Apache and MariaDB services.
- To configure Burp Suite as an intercepting proxy.
- To perform reconnaissance and traffic analysis.
- To identify application endpoints for future testing.

## The Tools Used Are

| Tool | Purpose |
|---|---|
| Kali Linux | Penetration Testing Platform |
| OWASP Juice Shop | Vulnerable Web Application |
| DVWA | Vulnerable Web Application |
| Docker | Container Deployment |
| Burp Suite Community Edition | Web Traffic Interception and Analysis |
| Firefox Browser | Accessing Web Applications |
| Nmap | Service Discovery and Reconnaissance |
| Apache2 | Web Server |
| MariaDB | Database Server |

# Study of OWASP Top 10 Vulnerabilities

Before starting practical activities, the OWASP Top 10 security risks were studied to understand the most common vulnerabilities affecting modern web applications.

The studied vulnerabilities included:

- Broken Access Control
- Cryptographic Failures
- Injection Attacks
- Insecure Design
- Security Misconfiguration
- Vulnerable Components
- Identification and Authentication Failures
- Software and Data Integrity Failures
- Security Logging and Monitoring Failures
- Server-Side Request Forgery (SSRF)

This theoretical understanding provided the foundation required for practical penetration testing activities.

# OWASP Juice Shop Deployment

OWASP Juice Shop was selected because it is one of the most widely used intentionally vulnerable web applications designed for cybersecurity training and penetration testing practice.

## Commands Used

- Check Docker Installation

  “Docker –version”

- Download OWASP Juice Shop Image

  “docker pull bkimminich/juice-shop”

- Run Juice Shop Container

  “docker run -d -p 3000:3000 bkimminich/juice-shop”

- Verify Running Containers

  “docker ps”

- Access Application

  “http://127.0.0.1:3000”

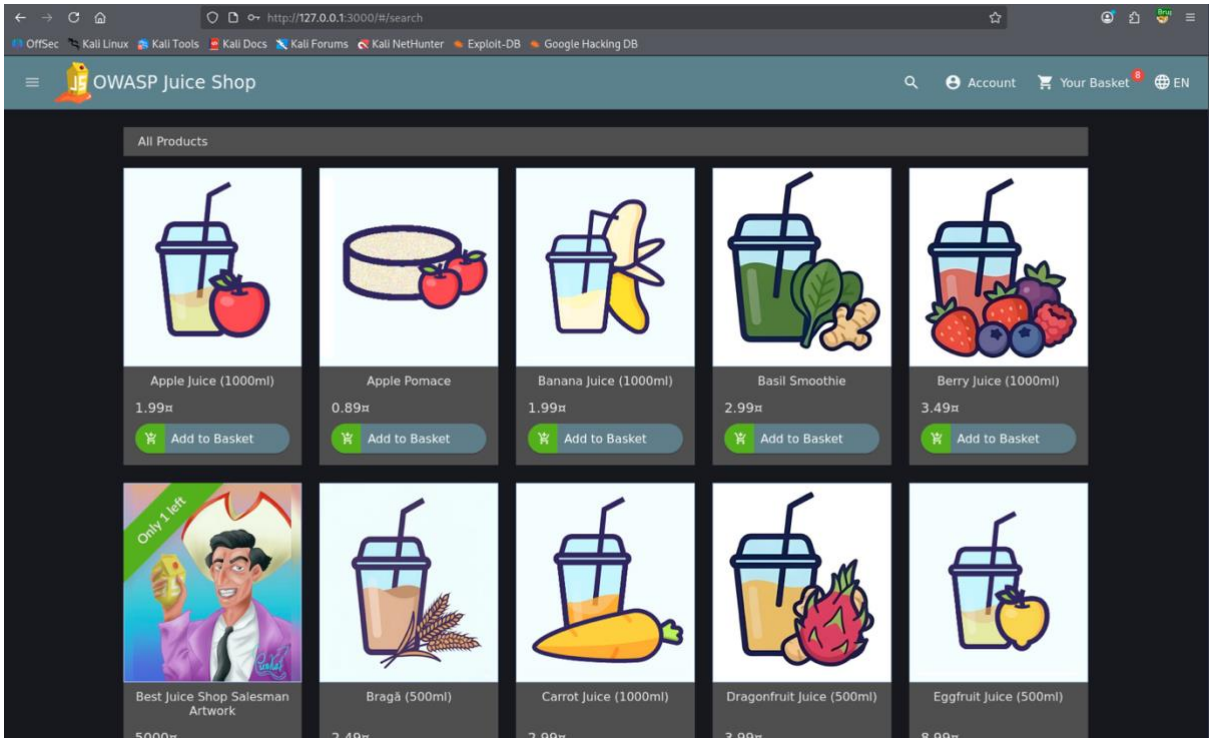


**Figure 1:** OWASP Juice Shop Homepage

```
┌──(root㉿kali)-[~]
└─# docker ps
CONTAINER ID   IMAGE                    COMMAND                  CREATED       STATUS       PORTS
 NAMES
c192fa9acbb9   bkimminich/juice-shop    "/nodejs/bin/node /j…"   16 hours ago   Up 16 hours   0.0.0.0:3000→3000/tcp, [::]:3000→3000/tcp
 fervent_snyder
```

**Figure 2:** Docker Container Running Successfully

# Service Verification

After configuring the environment, essential services were verified.

## Commands Used

- Check Apache Service

  `"systemctl status apache2"`

- Check MariaDB Service

  `"systemctl status mariadb"`

- Check Active Listening Ports

  `"ss -tulnp"`

## Findings

| Port | Service |
|---|---|
| 80 | Apache HTTP Server |
| 3000 | OWASP Juice Shop |
| 3306 | MariaDB Database Server |

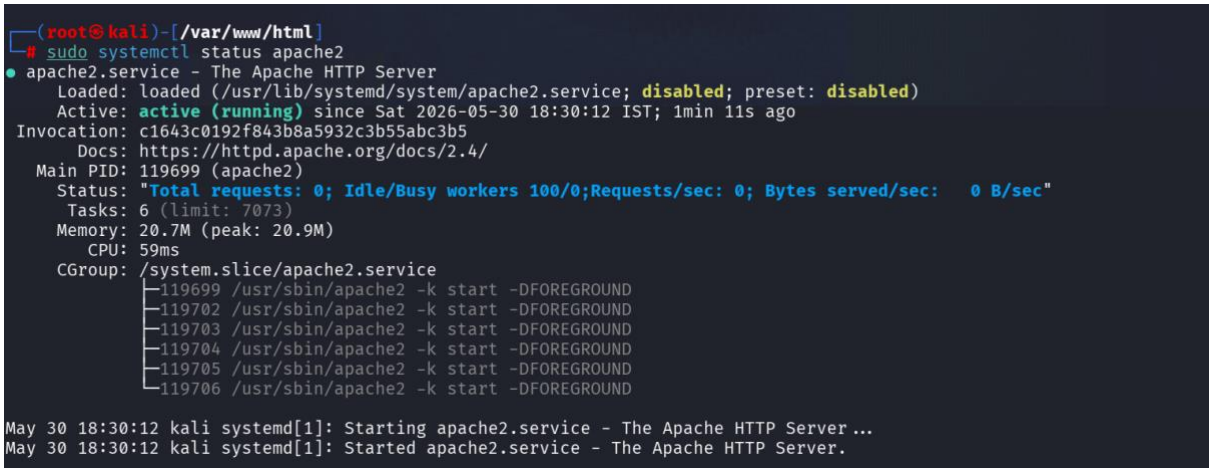


**Figure 3:** Apache Service Running

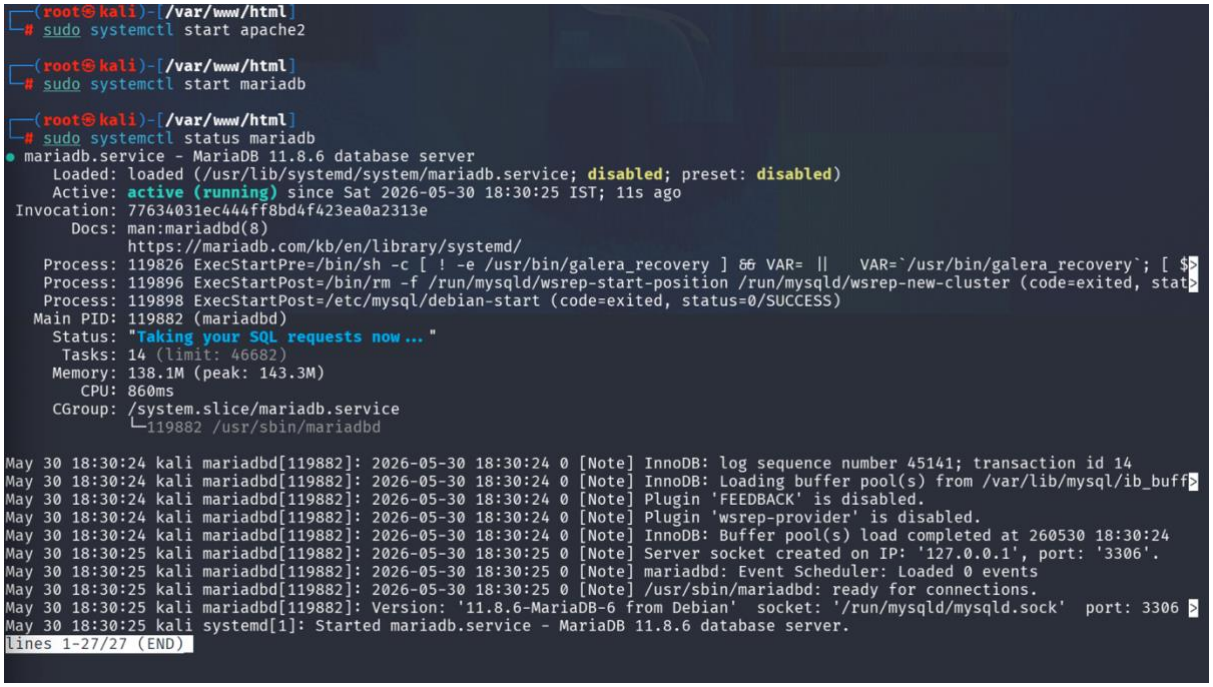


**Figure 4:** MariaDB Service Running

# Reconnaissance Using Nmap

Reconnaissance is the first phase of penetration testing where information about the target environment is collected.

## Command Used

`"nmap -sV 127.0.0.1"`

## Results

The Nmap scan successfully identified:

- Apache HTTP Server on Port 80
- OWASP Juice Shop on Port 3000
- MariaDB Database Service on Port 3306

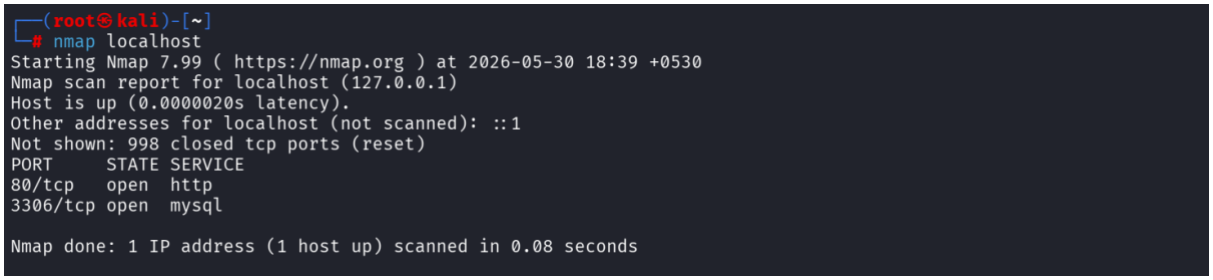


**Figure 5:** Nmap Service Version Detection Scan

# Burp Suite Configuration

Burp Suite Community Edition was configured as an intercepting proxy to analyze web application traffic.

## Launch Burp Suite

"burpsuite"

## Browser Proxy Settings

"HTTP Proxy : 127.0.0.1"
"Port : 8080"

## Activities Performed

- Configured Firefox Proxy Settings
- Enabled Request Interception
- Captured HTTP Requests
- Monitored HTTP Responses
- Analyzed API Endpoints

Burp Suite allowed complete visibility into communication between the browser and the web application. It helped identify API endpoints, request parameters, and application behavior which will be useful during vulnerability testing.

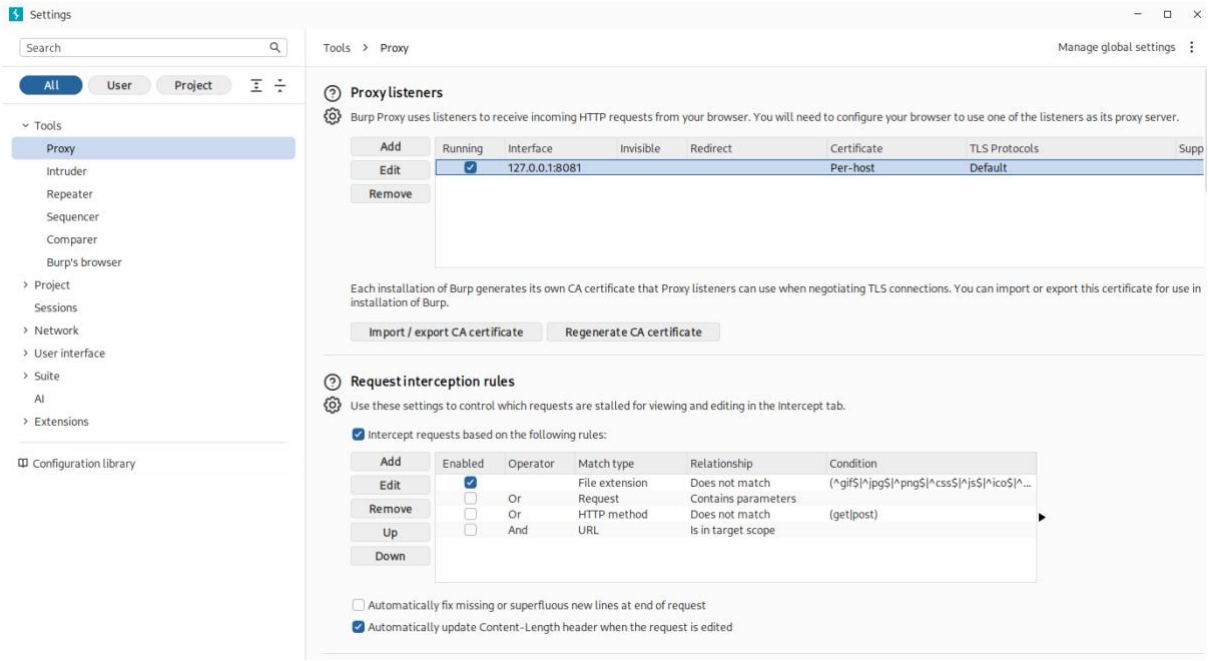


**Figure 6:** Burp Suite Proxy Configuration

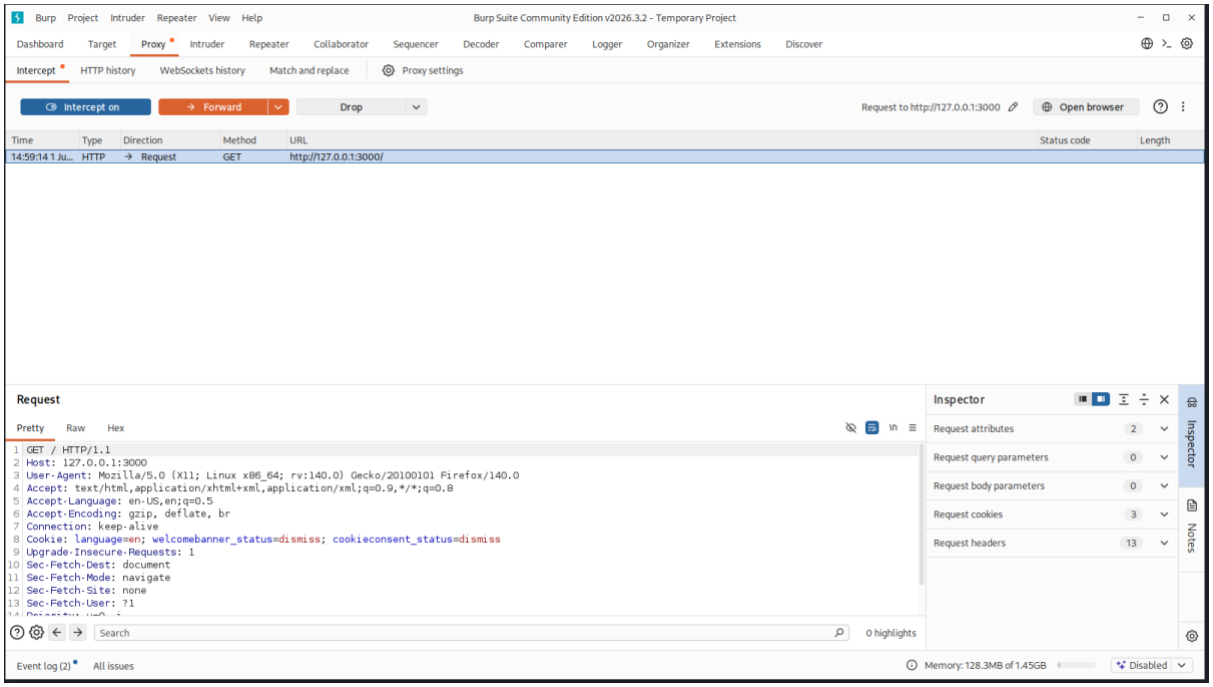


**Figure 7:** Intercepting HTTP Requests

# Traffic Analysis and Endpoint Discovery

After successful proxy configuration, application traffic was analyzed through Burp Suite HTTP History.

## Important Endpoints Identified

```
"/api/Products"
"/api/Challenges"
"/api/BasketItems"
"/api/Quantitys"
"/rest/admin/application-configuration"
```

The discovered endpoints indicated the presence of:

- Product Management Functions
- User Authentication Components
- Basket Operations
- Administrative Configuration Features
- Application Challenge Tracking

These endpoints will be used during future vulnerability testing phases.

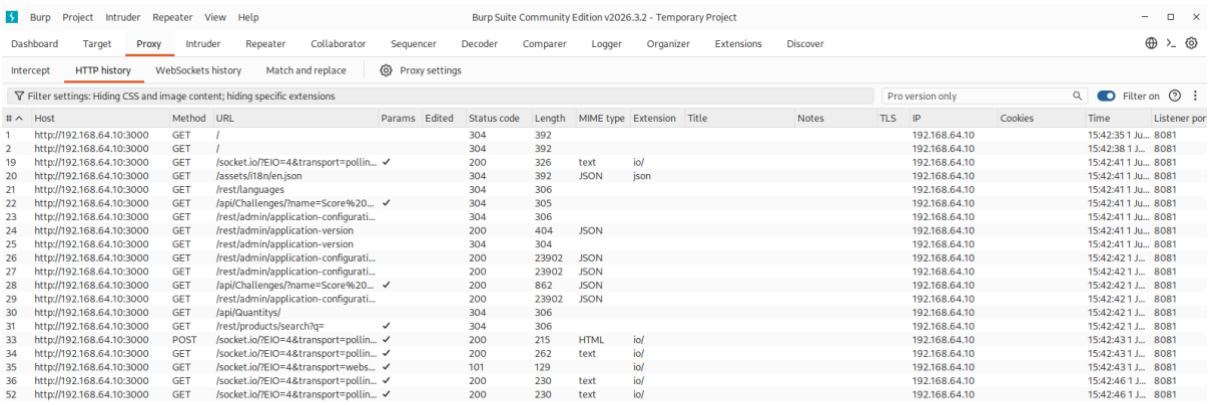


**Figure 8:** Burp Suite HTTP History

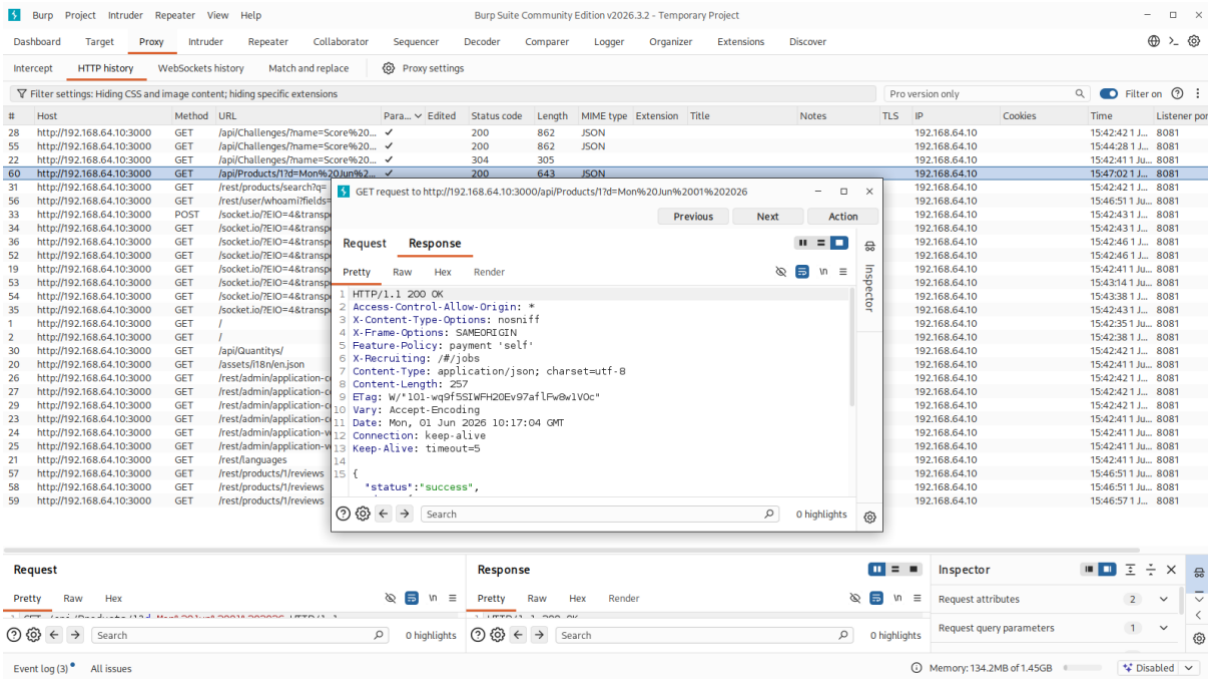


**Figure 9:** Captured Juice Shop API Requests

# The Issues Encountered and Resolutions I Have Done In This Project

## Issue 1: The Juice Shop was not Accessible due the faulty network setting issue from docker

**Cause:** Docker container was not running correctly.

**Solution:** Verified containers using Docker commands and restarted the application.

**Result:** Successfully accessed Juice Shop.

## Issue 2: The Burp Suite was not Capturing Traffic

**Cause:** Firefox proxy settings were not configured correctly.

**Solution:** Configured Firefox to use Burp Proxy (127.0.0.1:8080).

**Result:** Burp Suite successfully captured HTTP requests and responses.

### Issue 3: The empty site map in Burp Suite

**Cause:** Community Edition limitations.

**Solution:** Used HTTP History for traffic analysis.

**Result:** Successfully identified application endpoints.

During Week 1, the following observations were made:

- OWASP Juice Shop was successfully deployed using Docker.
- Apache and MariaDB services were operational.
- Nmap successfully identified active services.
- Burp Suite intercepted and analyzed web traffic successfully.
- Multiple API endpoints were discovered.
- The testing environment was successfully prepared for vulnerability assessment activities.

# Outcome

The Week 1 objectives were successfully completed.

Achievements:

- OWASP Top 10 vulnerabilities studied.
- Vulnerable web applications deployed.
- Penetration testing environment configured.
- Reconnaissance completed using Nmap.
- Burp Suite configured successfully.
- Application endpoints identified and documented.
- Environment prepared for OWASP Top 10 vulnerability testing.

# References link


1. OWASP Top 10 Project – https://owasp.org/www-project-top-ten/
2. OWASP Juice Shop – https://owasp.org/www-project-juice-shop/
3. PortSwigger Burp Suite Documentation – https://portswigger.net/burp/documentation
4. Nmap Official Documentation – https://nmap.org/book/man.html
5. Docker Documentation – https://docs.docker.com/